



An introduction to the community
powered vulnerability scanner.

Vulnerability Assessment using Nuclei

How do we efficiently identify vulnerabilities across
systems before attackers do?

By:

Aarya Patil (16010123008)

Bhoush Grover (16010123100)

Yuvaan Shah (16010123338)

What is Nuclei?

Nuclei is a fast, open-source, template-based vulnerability scanner developed by ProjectDiscovery. Unlike traditional scanners that rely on compiled binaries and vendor-defined checks, Nuclei uses community-contributed YAML templates to define exactly how each vulnerability is detected. This approach enables rapid response to newly disclosed CVEs and allows security teams to customize detection logic for their specific environments.

The scanner can simultaneously assess web applications, network services, DNS configurations, SSL/TLS certificates, and APIs in a single automated run. With over 9,900 templates covering CVEs, misconfigurations, exposed administrative panels, and weak security configurations, Nuclei provides comprehensive coverage without requiring expensive licenses or proprietary software.



CLI-Based

Command-line interface for automation and scripting



Open Source

Free to use, inspect, and modify the source code



Community-Driven

9,900+ templates contributed by security researchers worldwide

Core Features: Template-Based Scanning

Template Architecture

Every vulnerability check is defined by a YAML template containing a unique identifier, severity classification, descriptive tags, the exact network request to send, and matchers that define what constitutes a vulnerable response.

Templates are human-readable and easy to write, allowing security teams to create custom checks for organization-specific vulnerabilities or internal systems without waiting for vendor updates.

YAML Template Structure

```
id: example-vuln
info:
  name: Example Vulnerability
  severity: high
  tags: web, cve
requests:
  - method: GET
    path: /vulnerable/endpoint
  matchers:
    - type: word
      words: "vulnerable response"
```


Core Features: Multi-Protocol Support

Nuclei is not limited to web application scanning. It supports simultaneous testing across multiple protocols and network layers, providing a comprehensive view of an asset's attack surface.



HTTP/HTTPS

Web server scanning, API testing, and web application vulnerability detection



TCP/UDP

Port scanning, service identification, and network-level vulnerability checks



DNS

DNS record enumeration, subdomain discovery, and DNS misconfiguration detection



SSL/TLS

Certificate validation, cipher suite analysis, and TLS configuration auditing



SSH

SSH service banner analysis, algorithm negotiation testing, and protocol vulnerabilities



JavaScript

Dynamic network checks using JavaScript-based logic for complex vulnerability patterns

Core Features: Classification & Filtering

Severity Classification

All findings are automatically classified into five severity levels, enabling security teams to prioritize remediation efforts based on risk impact.

- **Critical** — Immediate remote code execution or data breach risk
- **High** — Significant security impact requiring prompt attention
- **Medium** — Moderate security implications and potential exploitation paths
- **Low** — Minor security concerns with limited impact
- **Info** — Informational findings for security awareness

The `-severity` flag filters output to show only specified severity levels.

Tag-Based Filtering

Templates are organized by descriptive tags including `cve`, `misconfig`, `exposure`, `network`, `ssl`, and `default-login`. Security teams can run targeted scans using the `-tags` flag to focus on specific vulnerability categories.

Example: `nuclei -u target -tags cve` runs only CVE-identified vulnerabilities, allowing efficient scanning without processing all 9,900+ templates unnecessarily.

Core Features: Reporting, Rate Control & Template Management



Output & Reporting

Save results as plain text (`-o report.txt`) or JSON Lines format (`-jsonl -o report.json`) for integration with other security tools and automated pipelines



Rate Limiting

Control scan aggression with `-rate-limit` and `-c` flags to prevent crashing targets or triggering intrusion detection systems — critical for professional use



Template Management

`nuclei -update-templates` keeps the library current; `nuclei -tl` lists available templates; `nuclei -validate` checks templates for errors before execution

How Nuclei Works: Architecture & Flow

Nuclei follows a streamlined seven-step process to identify vulnerabilities across multiple protocols simultaneously.



Target Input

User provides target URLs, IP addresses, or lists of assets to scan



Template Loading

Nuclei loads 9,900+ templates from local library



Optimization

Templates clustered and deduplicated to reduce redundant requests



Request Execution

Crafted requests sent via HTTP, TCP, DNS, SSH protocols



Response Matching

Responses analyzed against template-defined conditions



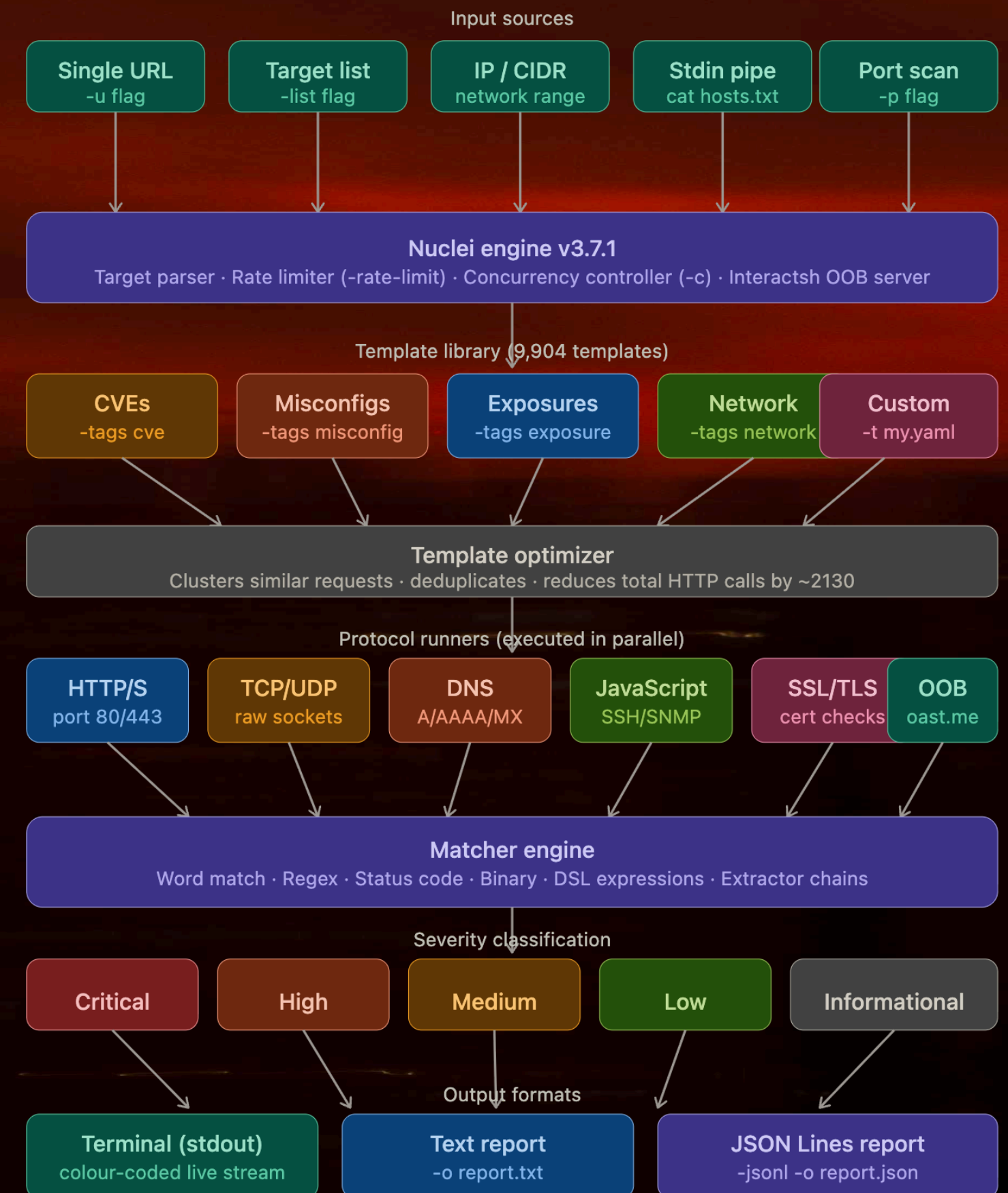
Findings Reporting

Matches reported with severity, evidence, and template ID



Result Export

Results exported to text or JSON output files



Installation & Experimentation Setup

Installation Commands

```
brew install nuclei  
nuclei -update-templates  
nuclei -version
```

Environment: macOS, Terminal,
Homebrew package manager

Version: Nuclei v3.7.1, templates v10.4.0,
9,904 templates loaded

No GUI required, no local server needed.
Runs directly from command line.

Target: **scanme.nmap.org**

A publicly available, legally scannable
practice server maintained by Nmap
specifically for security testing
demonstrations.

Important: Never scan targets without
explicit permission. This server is
provided for educational purposes only.

Outputs & Results

Four different scan configurations demonstrate Nuclei's flexibility and filtering capabilities.

1 Basic Full Scan nuclei -u http://scanme.nmap.org 31 findings in 4 minutes covering HTTP, SSH, and DNS services	2 Severity Filter nuclei -u http://scanme.nmap.org -severity medium,low Isolated actionable findings, removed informational noise
3 CVE Tag Scan nuclei -u http://scanme.nmap.org -tags cve Identified CVE-2023-48795 Terrapin Attack on SSH port 22	4 Misconfig Scan nuclei -u http://scanme.nmap.org -tags misconfig Found 11 missing HTTP security headers

Key Findings

CVE-2023-48795 Medium — SSH Terrapin Attack detected on port 22. Allows packet injection and manipulation during SSH session establishment	Weak SSH Algorithms Low — Outdated cryptographic algorithms detected. Server supports legacy cipher suites that should be disabled	Missing Security Headers Info — Apache 2.4.7 server lacks Content Security Policy (CSP) and X-Frame-Options headers
--	--	---

Security Implications & Applications:

Nuclei is deployed across diverse security operations by professional penetration testers, bug bounty hunters, and security engineers.



Bug Bounty Hunting

Quickly scan targets for known vulnerabilities and earn rewards from disclosed security issues



Penetration Testing

Comprehensive reconnaissance and vulnerability discovery during security assessments



Security Auditing

Regular automated checks on infrastructure to maintain security baseline compliance



CI/CD Integration

Catch vulnerabilities before code goes live in deployment pipelines and release cycles



CVE Verification

Confirm whether systems are affected by newly disclosed CVEs within hours of publication



Red Team Operations

Fast reconnaissance and attack surface mapping for offensive security engagements